EU AI Act Compliance Audit Report

Automated pipeline output | Timestamp: 23/05/2026, 6.44.43

Assessment Metadata

• Session ID: session_v5696s2ip
• Compliance Score: 75/100
• Regulatory Status: ACTION REQUIRED

1. Extracted Use-Case Facts (Source: Input Parser Agent)

Core Purpose: AI recruitment tool to scan and profile candidate CVs to predict job performance.
Target Sector: Employment and HR / Candidate evaluation (High-Risk Category Annex III of AI Act).
End Users: Corporate HR recruitment managers.
Affected Persons: Job applicants and candidates.
Deployment Context: Hosted as a cloud SaaS recruitment platform accessible via web browser.
Input Data Ingestion: Candidate curriculum vitaes (CVs), resume texts, LinkedIn profiles, self-reported skills, and cover letters.
Primary Outputs: Automated fit-score (0-100), key capability profiles, and suitability ranking.
GPAI Component Usage: Uses a fine-tuned GPT model via OpenAI API for capability extraction.
Automation Level: Highly automated screening, rank-ordering candidates.
Human Oversight Claims: Vague. HR managers can view scores and theoretically ignore them, but there is no built-in mechanism or operational rule ensuring human-in-the-loop validation of low-scored applicants.
Potential Social Impact: Equal employment opportunity, career livelihoods, systematic bias/discrimination based on historical CV data.

2. EU AI Act Path Classifications & Citations (Source: Decision Tree)

High-Risk AI System (Article 6.2 - Annex III Point 4 Employment & HR) with Integrated General Purpose AI (GPAI)

EU AI Act Flowchart Citations:

- Article 2 (Scope & Exclusions check - Determines if the system's deployment affects the EU market)
- Article 6.2 (High-Risk - Systems designated under Annex III high-risk use-case domains)
- Articles 9-15 (High-Risk Requirements - Risk management, data governance, technical file, logging, human oversight)
- Article 26 (Deployer Obligations - Controls, monitoring, human oversight compliance for AI deployers)
- Article 99.4e (Fines - Specific penalty framework for Deployer non-compliance)
- Article 51 (GPAI Classification - Classification of foundation models with general capabilities)
- Article 52 (Transparency - Mandatory notification to human users interacting with AI systems)
- Article 53 (GPAI Provider obligations - Documentation for downstream integrators and copyright policies)
- Article 101 (GPAI Penalties - Non-compliance fines specifically for general purpose AI model providers)
- Chapter IX (Post-Market Surveillance - Conformance framework for monitoring, info sharing, and market oversight)
- Article 99 (General Penalties and Fines framework - Outlines overall administrative enforcement)
- EU Legal Supremacy Disclaimer (The AI Act operates alongside, and does not replace, other sectoral EU laws)

3. Deduced Governance Observations (Source: Judge of Governance)

Human Oversight Framework: Recruitment HR managers can ignore algorithm scores.
Lifecycle Logging & Documentation: Basic user onboarding documentation is ready.
System Transparency & Disclosures: Privacy notice is displayed upon candidate login.
Risk Management Systems: Risk register outlines initial data protection impact assessment.
Audit Logging Mechanisms: RERUN_SUCCESS: Inferred system logs are stored in Amazon CloudWatch.
Organizational Accountability: Recruiting director is responsible for algorithmic hiring review.
Operational Role Clarity: Corporate HR is the deployer; SaaS platform is the provider.

4. Risk Boundaries: Assumptions & Gaps Checkers

Operational & Technical Assumptions Checked:

• Operational & Technical: The proposal for a "AI recruitment tool to scan and profile candidate CVs to predict job performance." targeting Corporate HR recruitment managers. assumes high-fidelity "Human-in-the-loop" oversight, claiming: "Vague. HR managers can view scores and theoretically ignore them, but there is no built-in mechanism or operational rule ensuring human-in-the-loop validation of low-scored applicants.". However, in real-world workflows, this creates a dangerous assumption that operators will actively review and verify the generated "Automated fit-score (0-100), key capability profiles, and suitability ranking." before taking action. In high-throughput, resource-scarce environments, clinical or corporate operators are highly prone to "automation bias"—passively accepting or rubber-stamping recommendations without independent cognitive verification, effectively transforming an advisory tool into an autonomous pipeline.

• Supply Chain & Role: The deployment of a "AI recruitment tool to scan and profile candidate CVs to predict job performance." within the Employment and HR / Candidate evaluation (High-Risk Category Annex III of AI Act). sector integrates upstream General Purpose AI (GPAI) capabilities, specifically: "Uses a fine-tuned GPT model via OpenAI API for capability extraction.". The development team assumes this legal setup positions them purely as a "Deployer" who is exempt from developer-level safety liabilities. However, under Article 28 of the EU AI Act, because this GPAI foundation is integrated, fine-tuned, or modified to serve a domain-specific High-Risk application, this assumption is legally invalid. It risks reclassifying the developer as the primary "Provider", transferring full conformity assessment, audit logging, and risk management compliance burdens onto them.

• Legal Interpretation: The proposal for a "AI recruitment tool to scan and profile candidate CVs to predict job performance." within the Employment and HR / Candidate evaluation (High-Risk Category Annex III of AI Act). assumes that candidate suitability ranking and CV profiling is a low/medium risk classification. However, under Annex III (Employment, worker management and access to self-employment), any AI system used for recruitment, screening, or candidate profiling is strictly designated as High-Risk. This carries severe pre-market compliance, fundamental rights impact assessments (FRIA), and national registration obligations regardless of the 'advisory' nature claimed in the pitch. Given the potential impact of "Equal employment opportunity, career livelihoods, systematic bias/discrimination based on historical CV data.", a failure to preemptively align with statutory High-Risk obligations risks immediate market withdrawal or massive administrative fines.

• Vulnerability & Impact: The proposal for a "AI recruitment tool to scan and profile candidate CVs to predict job performance." targeting "Job applicants and candidates." assumes that the system does not exploit human vulnerabilities or perpetuate structural inequalities. However, the system's impact on "Equal employment opportunity, career livelihoods, systematic bias/discrimination based on historical CV data." creates an inherent power asymmetry. Under Article 5 of the EU AI Act, systems must not utilize subliminal, manipulative, or exploitative techniques. By deploying automated grading/analysis against "Job applicants and candidates.", the system assumes that everyone has equal access and capability to challenge the algorithm, which is a high-risk assumption in real-world scenarios.

• Temporal & Lifecycle: Deploying the "AI recruitment tool to scan and profile candidate CVs to predict job performance." in the context of "Hosted as a cloud SaaS recruitment platform accessible via web browser." assumes that compliance obligations only commence once the product is fully commercialized. However, the EU AI Act applies the moment a system is 'placed on the market' or 'put into service' (even for trial/pilot programs in "Hosted as a cloud SaaS recruitment platform accessible via web browser."). The proposal assumes its rollout is exempt under research/sandbox clauses, but any operational use with live data activates full legal liabilities immediately. Furthermore, any future model updates or weight adjustments in "Hosted as a cloud SaaS recruitment platform accessible via web browser." are assumed to be simple maintenance patches, whereas they actually constitute a 'substantial modification' requiring brand-new conformity certifications.

• Geographic & Jurisdictional: The deployment plan for "AI recruitment tool to scan and profile candidate CVs to predict job performance." via "Hosted as a cloud SaaS recruitment platform accessible via web browser." assumes that geographic boundaries or external hosting provide a shield against EU regulatory jurisdiction. However, Article 2 of the AI Act establishes strict extraterritoriality: if the system's outputs are used or have effects within the European Union, the system is fully subject to the AI Act. This assumes that the location of the servers, developers, or operators in "Hosted as a cloud SaaS recruitment platform accessible via web browser." exempts the project, which is a major legal liability if EU residents are affected.

• Data Provenance: The proposal for a "AI recruitment tool to scan and profile candidate CVs to predict job performance." assumes that its input datasets ("Candidate curriculum vitaes (CVs), resume texts, LinkedIn profiles, self-reported skills, and cover letters.") are inherently balanced, high-quality, and legally compliant for processing. However, training or running models on "Candidate curriculum vitaes (CVs), resume texts, LinkedIn profiles, self-reported skills, and cover letters." assumes the absence of systemic or historical biases. In practice, this data frequently reflects entrenched patterns that, when processed, mathematically codify and perpetuate bias. This violates Article 10's strict data governance requirements, especially considering the system's potential impact on "Equal employment opportunity, career livelihoods, systematic bias/discrimination based on historical CV data.".

Identified Regulatory Assessment Gaps:

• [GAP IN ASSESSMENT] Missing Governance Area: 'Monitoring'. No operational notes, procedural evidence, or safety strategies were provided in the proposal for this AI Act mandate. This creates high liability and audit compliance risks.

5. Confidence Prevention & Auditing Queries (Prevention of Confidence Agent)

AI Compliance Expert Auditing Queries:

1. **Historical hiring and evaluation databases inherently encode race, gender, age, and regional biases. What rigorous mathematical audit methodology (e.g., disparate impact ratio, demographic parity checks) is being utilized to prevent the screening algorithm from codifying and perpetuating historical discrimination?**

2. **This CV ranking platform integrates third-party APIs (e.g., OpenAI GPT models) for capability extraction and candidate

profiling. How will the team handle data leakage, prompt injections, and legal compliance boundaries if the upstream provider alters model weights or deprecates API endpoints?**

3. **Under Annex III, candidate profiling for recruitment is strictly classified as a High-Risk AI System. How will you organize the mandatory pre-market Fundamental Rights Impact Assessment (FRIA), register the system in the EU database, and compile the exhaustive technical file for regulatory inspection?**

Advisory Footnote: This report displays a multi-agent automated compliance assessment to facilitate regulatory review. It does not constitute formal legal counsel or binding certification under the EU AI Act.